ROOTCAUSE SERVER

10 · Configuración

Documento: 10-configuration.md **Versión analizada:** 0.2.0 **Commit:** 2efedb2 **Fecha del análisis:** 2026-08-26

CONTENIDO

- Principio de diseño
- Dónde se configura
- Configuración del servidor
  - Red y almacenamiento
  - Autenticación
  - Perímetro propio
  - Detección y retención
  - Registros
- Configuración del agente
  - Etiquetas con significado
  - Riesgos de configuración del agente
- Diferencias entre entornos
- Banderas de funcionalidad
- Configuraciones sensibles
- Consecuencias de una configuración incorrecta — resumen

> Todos los archivos de configuración y variables del sistema, con sus valores por omisión, sus rangos válidos, sus diferencias entre entornos y **qué pasa si se configuran mal**.
>
> Ningún valor de este documento es un secreto real. Los tokens aparecen como `reemplaza-por-…` o `pega-aqui-el-token`.

Principio de diseño

`config.rs` lo declara en su cabecera: *cada ajuste que debilita la postura por omisión tiene que escribirlo un operador*. No hay un archivo de configuración que pueda abrir el servidor a la red en silencio, y `ServeSettings::validate` rechaza las combinaciones que lo intentarían.

Consecuencias prácticas:

- El servidor escucha en `127.0.0.1` salvo que alguien escriba otra cosa.
- Sin token no arranca, salvo que alguien escriba `--insecure-dev-mode`, y entonces solo puede escuchar en loopback.
- `--trust-forwarded-for` se rechaza si el enlace es loopback, porque ahí no hay proxy que justifique confiar en la cabecera.
- Una política de detección contradictoria **impide arrancar**.

Dónde se configura

Mecanismo	Precedencia	Uso típico
Opción de línea de comandos	Máxima	Desarrollo, pruebas puntuales
Variable de entorno	Media	Producción, servicios del sistema, contenedores
Valor por omisión del código	Mínima	Todo lo no especificado

`clap` resuelve la precedencia: la opción explícita gana sobre la variable, y la variable sobre el valor por omisión.

No se lee ningún archivo `.env` automáticamente. `.env.example` es una plantilla para el `EnvironmentFile=` de systemd, para el bloque `environment:` de Compose o para exportar a mano.

Configuración del servidor

Red y almacenamiento

Variable	Opción	Por omisión	Rango	Obligatoria
`ROOTCAUSE_BIND`	`--bind`	`127.0.0.1:8080`	Dirección y puerto válidos	No
`ROOTCAUSE_DATABASE_URL`	`--database-url`	`sqlite://rootcause.db`	Debe empezar por `sqlite:`	No

Si se configura mal:

- `--bind 0.0.0.0:8080` sin TLS delante **publica la consola y el API en toda la red**. El servidor lo advierte al arrancar con un `warn!` y lo declara en `hardening.bind_is_loopback: false`, que la consola muestra como aviso permanente. No lo impide: el operador puede tener razones.
- Una URL que no sea `sqlite:` hace fallar el arranque con un mensaje explícito.
- Una ruta de base de datos en un sistema de archivos de solo lectura hace fallar la conexión. En el contenedor, por eso el volumen se monta en `/var/lib/rootcause` aunque el resto sea `read_only`.

Autenticación

Variable	Opción	Por omisión	Restricciones
`ROOTCAUSE_API_TOKEN`	`--api-token`	*(sin valor)*	≥ 32 caracteres, sin espacios al inicio ni al final
`ROOTCAUSE_INSECURE_DEV_MODE`	`--insecure-dev-mode`	`false`	Solo con enlace en loopback

`clap` marca la opción con `hide_env_values = true`, así que el token **no aparece en la ayuda ni en los mensajes de error**.

Si se configura mal:

Error	Qué ocurre
Token de menos de 32 caracteres	El arranque falla
Token con espacio envolvente	El arranque falla. Es el fallo de copiar y pegar más común, y se rechaza antes de causar un desajuste inexplicable
Sin token y sin modo de desarrollo	El arranque falla, indicando cómo generar uno

Error	Qué ocurre
Modo de desarrollo fuera de loopback	El arranque falla
Token pasado por línea de comandos	**Funciona, pero queda en el historial del shell y es visible en `ps`.** `.env.example` advierte explícitamente contra ello

Perímetro propio

Variable	Opción	Por omisión	Rango
`ROOTCAUSE_RATE_LIMIT_PER_MINUTE`	`--rate-limit-per-minute`	`600`	10 – 100 000
`ROOTCAUSE_LOCKOUT_THRESHOLD`	`--lockout-threshold`	`10`	3 – 1 000
`ROOTCAUSE_LOCKOUT_SECONDS`	`--lockout-seconds`	`300`	30 – 86 400
`ROOTCAUSE_MAX_BODY_KIB`	`--max-body-kib`	`1024`	16 – 16 384
`ROOTCAUSE_TRUST_FORWARDED_FOR`	`--trust-forwarded-for`	`false`	Incompatible con loopback

Los rangos los aplica `clap` con `value_parser!(...).range(...)`: un valor fuera de rango es un error de línea de comandos, no un valor recortado en silencio.

Si se configura mal:

Error	Consecuencia
Límite de tasa demasiado bajo	Los agentes propios acaban limitados. Con 10 agentes reportando cada 30 s son 40 peticiones/minuto; el valor por omisión de 600 deja margen amplio. **Cuidado si todos los agentes salen tras el mismo NAT**: comparten dirección y por tanto cubeta
Umbral de bloqueo muy bajo	Un operador que teclea mal el token unas pocas veces se bloquea a sí mismo durante `lockout_seconds`
Bloqueo muy largo	Un falso positivo deja fuera a un agente legítimo hasta 24 h
Cuerpo máximo muy pequeño	Un agente con muchos sockets recibe `413`; se pierde el ciclo
`--trust-forwarded-for` sin proxy	Sería el error grave: cualquiera podría elegir qué dirección se limita y se bloquea, saltándose el perímetro y pudiendo bloquear a terceros. **Por eso el servidor rechaza la combinación con loopback**, aunque no puede detectar todos los casos: un enlace en `0.0.0.0` sin proxy delante sí lo aceptaría. *Responsabilidad del operador*

Detección y retención

Variable	Opción	Por omisión	Rango
`ROOTCAUSE_POLICY_FILE`	`--policy-file`	*(sin valor)*	JSON `DetectionPolicy` válido
`ROOTCAUSE_RETENTION_DAYS`	`--retention-days`	`30`	1 – 3 650
`ROOTCAUSE_AGENT_INTERVAL_SECONDS`	`--agent-interval-seconds`	`30`	5 – 3 600

`--agent-interval-seconds` del servidor no controla al agente. Es lo que el servidor *espera*, y con ello decide cuándo un agente lleva demasiado tiempo callado. Si los agentes reportan cada 60 s y el servidor cree que es cada 30 s, la regla `availability.agent.silence` se dispara antes de lo debido. **Ambos valores deben coincidir.**

Si se configura mal:

Error	Consecuencia
Política contradictoria	**El servidor no arranca.** Es deliberado: una política que no puede dispararse parece defensa y no la proporciona
Campo mal escrito en la política	`deny_unknown_fields` lo convierte en error de arranque, no en un valor ignorado
Retención muy corta	Las reglas con ventana pierden historial. Con 1 día y muestras cada 30 s aún sobra para las 12 muestras que usa el motor, pero desaparece la traza de amenazas
Retención muy larga	El archivo SQLite crece. *Requiere validación* del tamaño en cada despliegue
Intervalo de agente desalineado	Falsos positivos de silencio, o silencios reales detectados tarde

Registros

Variable	Por omisión	Formato
`ROOTCAUSE_LOG`	`rootcause_server=info,tower_http=warn`	Sintaxis `EnvFilter` de `tracing-subscriber`
`ROOTCAUSE_JSON_LOGS`	`false`	`true` para salida JSON estructurada

Ejemplos: `rootcause_server=debug` para depurar; `rootcause_server=warn` para reducir volumen.

Cuidado con `trace`: aumenta mucho el volumen. El código está escrito para no registrar tokens, credenciales, datos personales ni cuerpos sin límite (regla explícita de `AGENTS.md`), pero un nivel muy verboso de las bibliotecas sí puede sacar cabeceras. *Requiere validación* antes de usarlo en producción.

Configuración del agente

Variable	Opción	Por omisión	Rango
`ROOTCAUSE_SERVER_URL`	`--server-url`	`http://127.0.0.1:8080`	Esquema `http` o `https`
`ROOTCAUSE_API_TOKEN`	`--api-token`	**obligatorio**	≥ 32 caracteres
`ROOTCAUSE_AGENT_INTERVAL_SECONDS`	`--interval-seconds`	`30`	5 – 3 600
`ROOTCAUSE_AGENT_METRICS_ONLY`	`--metrics-only`	`false`	—
`ROOTCAUSE_AGENT_AUTH_WINDOW_MINUTES`	`--auth-window-minutes`	`15`	1 – 1 440
`ROOTCAUSE_WATCH_FILES`	`--watch-list`	*(sin valor)*	Rutas separadas por coma

Solo por línea de comandos: `--once`, `--dry-run`, `--allow-insecure-http`, `--watch-file` (repetible), `--label clave=valor` (repetible).

Etiquetas con significado

Dos etiquetas cambian el comportamiento del sistema, el resto son descriptivas:

Etiqueta	Valores aceptados	Efecto
`role`	`edge` / `edge-server` / `borde`, `internal` / `internal-server` / `interno`, `database` / `database-server` / `db` / `base-de-datos`, `workstation` / `estacion` / `estación`	**Cambia qué se considera normal.** Un servidor de borde puede publicar 80 y 443; uno de base de datos alcanzable públicamente es siempre crítico
`environment`	Texto libre	Descriptiva; se muestra en la consola

Si no se declara el rol, el activo es `internal-server`. Para un servidor web público eso significa que sus puertos 80 y 443 aparecerán como hallazgos de exposición. No es un fallo: es el valor por omisión más restrictivo.

Riesgos de configuración del agente

Error	Consecuencia
URL `http://` remota sin `--allow-insecure-http`	El agente **no arranca**. Es lo correcto: el token viajaría en claro
`--allow-insecure-http` en producción	El token viaja en claro por la red. **Nunca hacerlo fuera de un laboratorio**
`--metrics-only` sin decirlo a nadie	La consola muestra el equipo con postura basada solo en recursos y el servidor añade la advertencia *«el agente no envió superficie de seguridad»*
Ventana de autenticación muy larga	El agente relee minutos de registro en cada ciclo; con 1 440 minutos, cada 30 s, es trabajo desperdiciado
`--watch-list` en lugar de `--watch-file`	`--watch-list` **reemplaza** los valores por omisión de la plataforma; `--watch-file` los complementa. Confundirlos deja de vigilar `sshd_config` y `sudoers`
Intervalo distinto al del servidor	Falsos positivos de silencio

Diferencias entre entornos

Ajuste	Desarrollo	Pruebas / CI	Producción
Token	Generado por `scripts/dev.sh`, o `--insecure-dev-mode`	Fijo en la prueba de humo	Obligatorio, de al menos 32 caracteres, fuera del historial
Enlace	`127.0.0.1:8080`	`127.0.0.1:18080` (`ROOTCAUSE_SMOKE_PORT`)	Loopback tras proxy, o `0.0.0.0` en contenedor con el puerto publicado solo en loopback del anfitrión
Base de datos	`sqlite://rootcause.db` local	`sqlite::memory:` en las pruebas	Volumen o ruta persistente con respaldo
TLS	Ninguno	Ninguno	**Obligatorio**, terminado por el proxy
Registros	Compactos	Compactos	JSON (`ROOTCAUSE_JSON_LOGS=true`)
`trust_forwarded_for`	`false`	`false`	`true` **solo** si hay proxy
Retención	Por omisión	Irrelevante	Ajustada a la política de conservación del operador
Política	Por omisión	Por omisión	Archivo versionado junto al despliegue

Banderas de funcionalidad

No hay un sistema de *feature flags*. Lo más parecido son cuatro interruptores booleanos, todos con el valor seguro por omisión:

Bandera	Por omisión	Qué activa
`--insecure-dev-mode`	`false`	API sin token, solo en loopback
`--trust-forwarded-for`	`false`	Leer `X-Forwarded-For`
`--json-logs`	`false`	Registros estructurados

Bandera	Por omisión	Qué activa
`--metrics-only` (agente)	`false`	Omitir toda la superficie de seguridad
`--allow-insecure-http` (agente)	`false`	Enviar el token por HTTP remoto

En Cargo hay features de dependencias, pero ninguna condiciona la lógica del producto.

Configuraciones sensibles

Elemento	Sensibilidad	Cómo se protege	Cómo **no** protegerlo
`ROOTCAUSE_API_TOKEN`	**Alta.** Da acceso total al API	Variable de entorno; `hide_env_values`; comparación en tiempo constante; nunca se registra	No ponerlo en la línea de comandos, ni en un `.env` versionado, ni en el archivo de un servicio legible por todos
Archivo de base de datos	Media. Contiene direcciones IP y nombres de usuario	Permisos del sistema de archivos; usuario dedicado en systemd y en el contenedor	No dejarlo en un directorio compartido
Archivo de política	Baja	—	—
`EnvironmentFile` de systemd	**Alta.** Contiene el token	Debe pertenecer a `root` con modo `0600`	No dejarlo legible por todos

Ningún secreto real está en el repositorio. Se verificó de dos maneras: `gitleaks` recorre el histórico en el workflow de seguridad con una lista de permitidos estrecha (`.gitleaks.toml`), y este análisis revisó `.env.example` , `compose.yml` , las unidades de `packaging/` y los workflows. Todos los valores son plantillas.

Consecuencias de una configuración incorrecta — resumen

Gravedad	Configuración	Efecto
Crítica	`--trust-forwarded-for` con enlace público y sin proxy	Cualquiera elige qué dirección se limita y se bloquea
Crítica	`--allow-insecure-http` en el agente, en producción	El token viaja en claro
Alta	`--bind 0.0.0.0` sin TLS delante	Consola y API expuestos sin cifrar
Alta	Token débil o compartido fuera del equipo	Acceso total al API
Alta	`EnvironmentFile` legible por todos	Fuga del token
Media	Intervalo del agente distinto al del servidor	Falsos positivos de silencio
Media	Rol no declarado en un servidor de borde	Ruido de exposición en 80 y 443
Media	`--watch-list` confundido con `--watch-file`	Se deja de vigilar la lista por omisión
Baja	Límite de tasa muy bajo con agentes tras NAT	Agentes propios limitados
Baja	Retención muy corta	Se pierde traza histórica; los incidentes se conservan igual

Anterior: 09 · APIs e integraciones · **Siguiente:** 11 · Seguridad · **Índice:** README